Basics of Information Security (4360702)

Semester – 6th

Diploma in Computer Engineering

Prepared By:

Lecturer in Computer Engg. Department

A.V.P.T.I, Rajkot

Chapter 3
Public Key Cryptography

Topics To be Covered

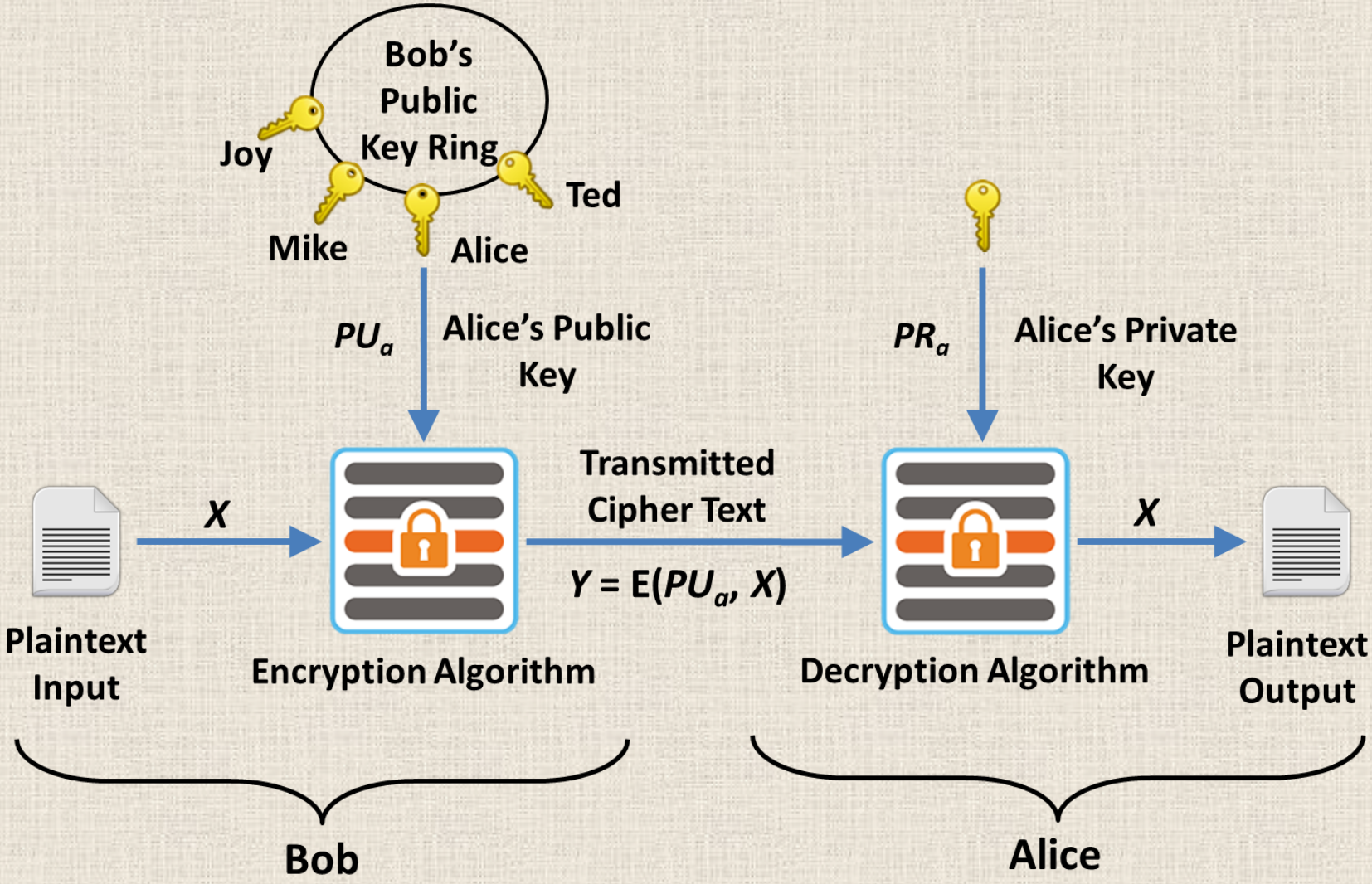
- Principles and Applications of Public Key Cryptosystems.
- RSA Algorithm (Description, Computational Aspects and Security).
- Digital Signature
- Public Key Infrastructures (PKI)
  - Digital Certificate
    - ✓ Certificate Authorities
    - ✓ Registration Authorities
    - ✓ Steps for Obtaining a Digital Certificate
    - ✓ Steps for Verifying Authenticity and Integrity of a Digital Certificate.

Asymmetric Key Encryption (Public Key Cryptosystems)

- Asymmetric Key Encryption also referred to as Public Key Encryption or Public Key Cryptosystems and It uses Pair of Keys : Public Key and Private Key
- Asymmetric encryption system has the following components:
  - Plain Text (PT)
    - *This is the original intelligible message or data that is fed into the algorithm as input.*
  - Encryption Algorithm
    - *The Encryption Algorithm Performs various substitutions and transformations operation on plaintext, It takes in Plain Text and key as a input and Produce the Cipher Text.*
  - Public and Private Key
    - *This is a pair of keys that have been selected so that if one is used for encryption, the other is used for decryption.*
  - Cipher Text (CT)
    - *This is the unintelligible message produced as output and It depends on the plaintext and the key.*
  - Decryption Algorithm
    - *This is essentially the Encryption Algorithm run in reverse, It takes the Cipher Text and the key as a input and produces the original Plain Text.*

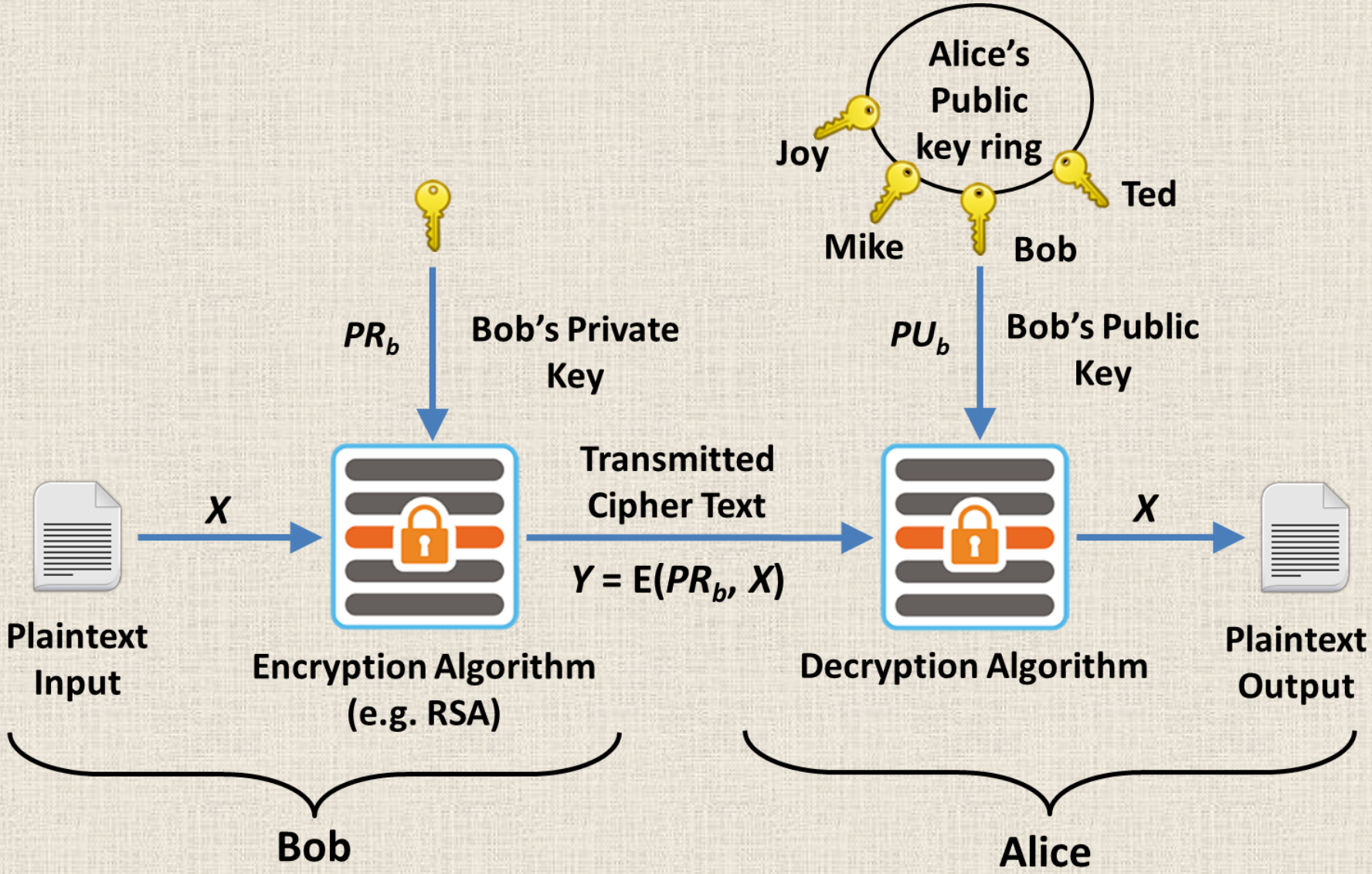
➢ Asymmetric Key Encryption With Public Key: Confidentiality

- Public Key cryptography plays a key role in achieving both confidentiality and authentication in secure communication.
- Using this We Achieves Confidentiality.
- Key Point: When Party A wants to send a confidential message to Party B, Party A uses Party B's Public Key to Encrypt the message, Only Party B, Possessing the Corresponding Private Key, can Decrypt and read the message.
- Each User generates a pair of keys to be used for the encryption and decryption of messages.
- Each user places one of the two keys in a public register or other accessible file, This is the public key, The other key is kept private that is Private Key.
- Here Bob Wishes to send a confidential message to Alice then Bob Encrypts the message using Alice Public Key.
- When Alice receives the message, it Decrypts it using his Private key, No other recipient can Decrypt the message because only Alice knows its Private Key.
- As long as a user's private key remains protected and secret, Communication is secure hence we achieve Confidentiality.
- Expression for Encryption: $Y = E(PUa, X)$
- Expression for Decryption: $X = D(PRa, Y)$


Bob's
Public
Key Ring
Joy
Mike
Alice
Ted
PU_a
Alice's Public
Key
PR_a
Alice's Private
Key
X
Transmitted
Cipher Text
$Y = E(PU_a, X)$
X
Plaintext
Input
Encryption Algorithm
Decryption Algorithm
Plaintext
Output
Bob
Alice

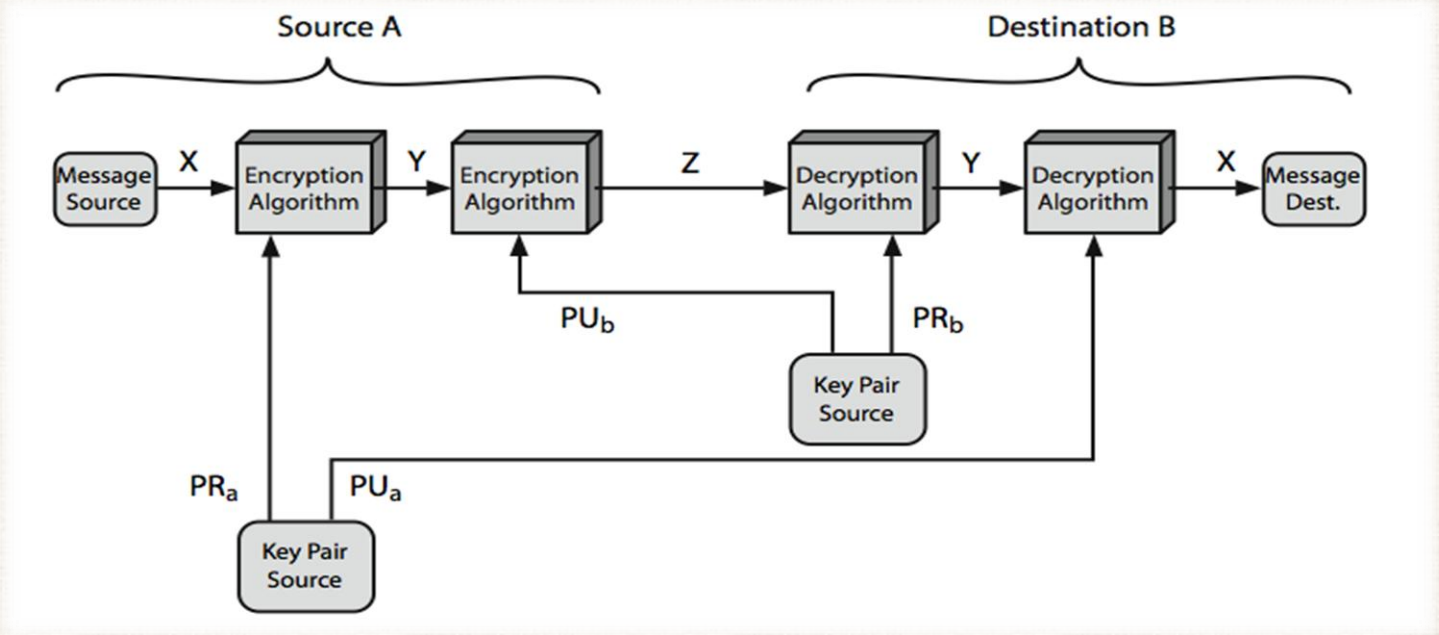
➢ Asymmetric Key Encryption With Private Key: Authentication

- Public Key cryptography plays a key role in achieving both confidentiality and authentication in secure communication.
- Using this We Achieves Authentication.
- Key Point: Public Key Cryptography enables the use of digital signatures for authentication, A party can sign a message using their private key, and anyone with access to the public key can verify the signature. This process ensures the authenticity and integrity of the message, as only the private key holder could have produced a valid signature.
- Each User generates a pair of keys to be used for the encryption and decryption of messages.
- Each user places one of the two keys in a public register or other accessible file, This is the public key, The other key is kept private.
- Here Bob Wishes to send a message to Alice then Bob Encrypts the message using Bob Private Key, When Alice receives the message, it Decrypts it using the Bob Public key.
- Expression for Encryption: $Y = E(PRb, X)$
- Expression for Decryption: $X = D(PUb, Y)$


Alice's
Public
key ring
Joy
Ted
Mike
Bob
PR_b
Bob's Private
Key
PU_b
Bob's Public
Key
Transmitted
Cipher Text
$Y = E(PR_b, X)$
X
X
Plaintext
Input
Encryption Algorithm
(e.g. RSA)
Decryption Algorithm
Plaintext
Output
Bob
Alice

➢ Asymmetric Key Encryption : Authentication and Confidentiality

- Public Key cryptography plays a key role in achieving both confidentiality and authentication in secure communication.
- Using this We Achieves Authentication and Confidentiality Both Together.
- Key Point: First Encrypt message with Private Key of Sender to Achieve Authentication and Then Output of that is Encrypt using Public Key of Receiver to achieve Confidentiality as we discussed earlier, and Reverse on Receiver End to Decrypt the message.
- Expression for Encryption: Z = E(PUb, E(PRa, X))
- Expression for Decryption: X = D(PUa, D(PRB, Z))



➢ Application of Public Key Cryptosystems

- Public-key cryptosystems play a crucial role in ensuring secure communication and data protection in various applications.
- Here are some common applications for public-key cryptosystems:
  - Secure Communication (e.g. Email Encryption and VPN)
  - Digital Signatures (e.g. Document Authentication)
  - Secure File Transfer
  - Cryptographic Key Exchange
  - Secure Access and Authentication
  - Blockchain
  - Digital Wallets
  - Cryptocurrencies
  - Secure VoIP (Voice Over Internet Protocol)
  - Secure IoT (Internet of Things)

RSA Algorithm

- The RSA algorithm was introduced in a paper titled "A Method for Obtaining Digital Signatures and Public-Key Cryptosystems" published in 1977 by Ron Rivest, Adi Shamir, and Leonard Adleman, who were researchers at the Massachusetts Institute of Technology (MIT).
- The RSA Algorithm is a widely used public-key cryptography Algorithm that enables secure data transmission and digital signatures
- In RSA, Plain Text and Cipher Text are represented as integers between 0 and n-1 for some n, also large messages can be broken up into a number of blocks, each block would then be represented by an integer.
- Steps of RSA Algorithm:
    1. Generate Public Key and Private Key
    2. Encrypt Message using Public Key
    3. Decrypt Message using Private Key

Step:1 (Generate Public Key and Private Key)

- Select Two Prime Numbers : p and q
- Calculate Modulus : $n = p * q$
- Calculate Euler's Totient Function : $\phi(n) = (p-1) * (q-1)$
- Select e such that e is relatively prime to $\phi(n)$ and $1 <= e < \phi(n)$
- Determine d such that $d * e \equiv 1 \pmod{\phi(n)}$
- Public Key = { e, n }
- Private Key = { d, n }

Note: Two numbers are relatively prime if they have no common factors other than 1.

Example:

- Select Two Prime Numbers: $p = 3$ and $q = 11$
- Calculate Modulus : $n = p * q$

  $n = 33$
- Calculate Euler's Totient Function : $\phi(n) = (p-1) * (q-1)$

  $\phi(n) = (3 – 1) * (11 – 1)$

  $\phi(n) = 20$
- Select e such that e is Relatively Prime to $\phi(n)$ and $1 < e < \phi(n)$

  We have several choices for e : 7, 11, 13, 17, 19

  Let's take $e = 7$
- Determine d such that $d * e \equiv 1 \pmod{\phi(n)}$

  $? * 7 \equiv 1 \pmod{20}$

  $3 * 7 \equiv 1 \pmod{20}$

  $d = 3$
- Public Key = { e, n } , PU = { 7, 33 }
- Private Key = { d, n }, PR = { 3, 33 }

- This is equivalent to finding d which satisfies

  $d\ e = (1 + I * \phi(n))$ where $i=1,2,3$ up to req.
- We can rewrite this as

  $d = (1 + i * \phi(n)) / e$
- Increment value of i every time when you got d without fractional part then stop, that is your final d

➢ Step: 2 (Encrypt Message using Public Key)

$$C = P^e \bmod n$$

Cipher Text

Input Message

Public Key

Public Key = { e, n } , PU = { 7, 33 }

For Message P = 14

$C = 14^7 \bmod 33$

$C = [(14^1 \bmod 33) \times (14^2 \bmod 33) \times (14^4 \bmod 33)] \bmod 33$

$C = (14 \times 31 \times 4) \bmod 33 = 1736 \bmod 33$

$C = 20$

➢ Step: 3 (Decrypt Message using Private Key)

$$P = C^d \bmod n$$

Plain Text

Cipher Text

Private Key

Private Key = { d, n } = { 3, 33 }

For Cipher Text C = 20

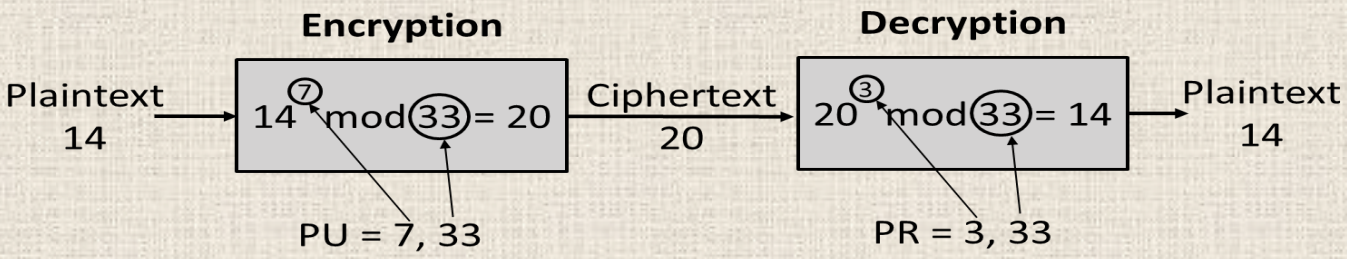
$P = 20^3 \bmod 33$

$P = [(20^1 \bmod 33) \times (20^2 \bmod 33)] \bmod 33$

$P = (20 \times 4) \bmod 33 = 80 \bmod 33$

$P = 14$

- The Overall Process of RSA Algorithm are depicted below,



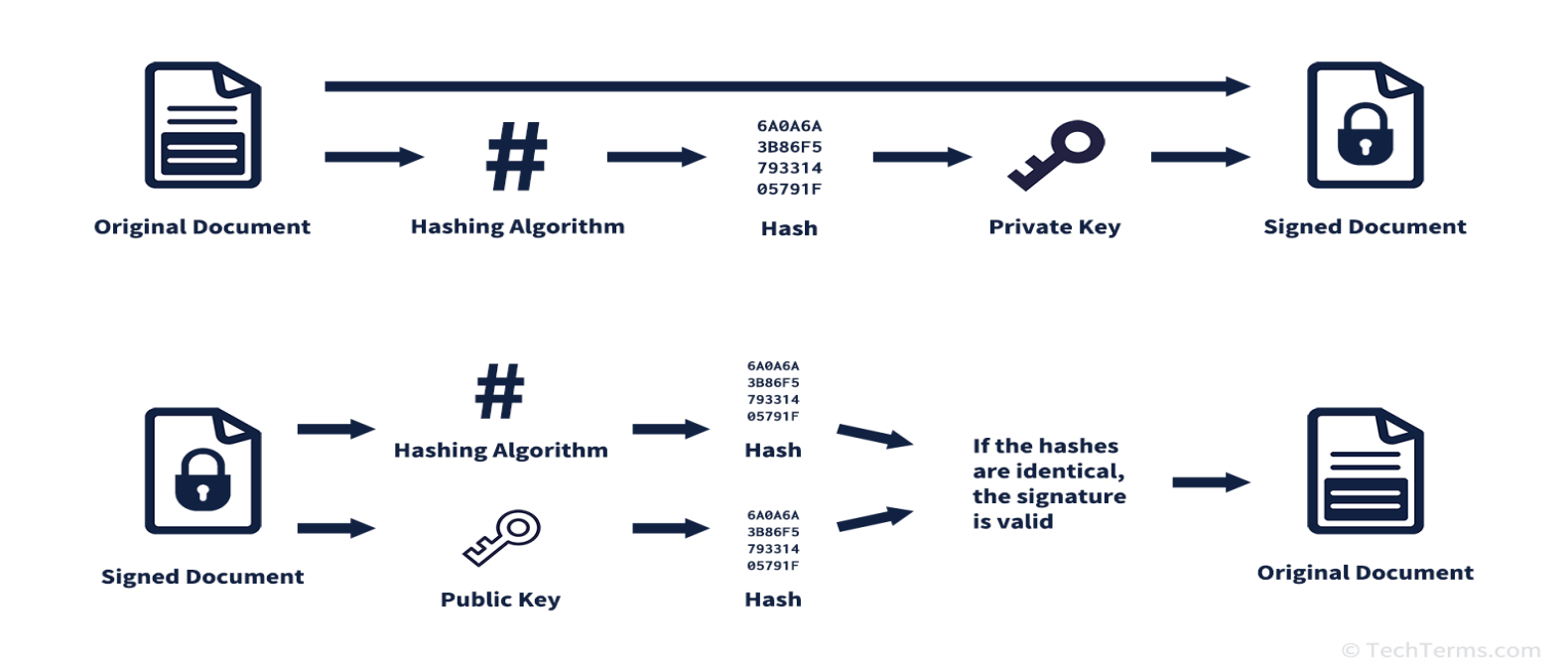
- Application of RSA Algorithm
  - Establishment of Secure Communication
  - Development of Secure Communication Protocols
  - Digital Signatures
  - Blockchain and Cryptocurrencies
  - Cryptographic Key Exchange
  - Software Protection

- Security Aspect of RSA Algorithm
  - The RSA algorithm, a widely used public-key cryptosystem, relies on the difficulty of factoring large numbers for security.
  - Security Key aspects include:
    - Key Size: Larger key sizes enhance security.
    - Key Generation: Random and unpredictable key generation is crucial.
    - Randomness: High-quality random number generation is essential.
    - Key Distribution: Securely distribute public keys to prevent man-in-the-middle attacks.
    - Key Management: Securely store and manage keys, protecting them against unauthorized access.
    - Cryptanalytic Attacks: Regularly update cryptographic algorithms and key sizes to counter potential breakthroughs.
    - Certificates and Trust Chain: Properly manage digital certificates and trust chains in a PKI environment.
    - Regular Security Audits: Conduct routine security audits to identify and address vulnerabilities in both the algorithm and its implementation.

- Advantages of RSA Algorithm
  - Security: RSA provides strong security, relying on the difficulty of factoring large semiprime numbers.
  - Public-Key Cryptography: RSA is a popular public-key cryptography algorithm, allowing secure communication without a need for both parties to share a secret key beforehand.
  - Digital Signatures: RSA is commonly used for digital signatures, providing a way to verify the authenticity and integrity of messages.
  - Key Exchange: It facilitates secure key exchange, a critical component in many secure communication protocols.
  - Versatility: RSA is versatile and can be used for various cryptographic applications, including encryption, digital signatures, and key exchange.
  - Standardization: RSA has been widely standardized and implemented, making it a well-established and accepted cryptographic algorithm.
- Disadvantages of RSA Algorithm
  - Key Size and Performance: Larger key sizes are needed for stronger security.
  - Key Management: Key management is crucial, and the secure distribution of public keys is a challenge.
  - Quantum Computing Vulnerability: RSA is vulnerable to attacks by quantum computers using Shor's algorithm, which can efficiently factor large numbers.

Digital Signature

- Digital signatures are a cryptographic technique used to provide authentication, integrity, and non-repudiation in digital communications and It ensure that a message or document has been created by a particular entity (authentication), has not been altered during transit (integrity), and the sender cannot later deny having sent the message (non-repudiation).
- Common algorithms used for digital signatures include RSA.
- Digital signatures are widely used in various applications, including email security, online transactions, document signing, and digital contracts.
- The Overall Process is depicted below;

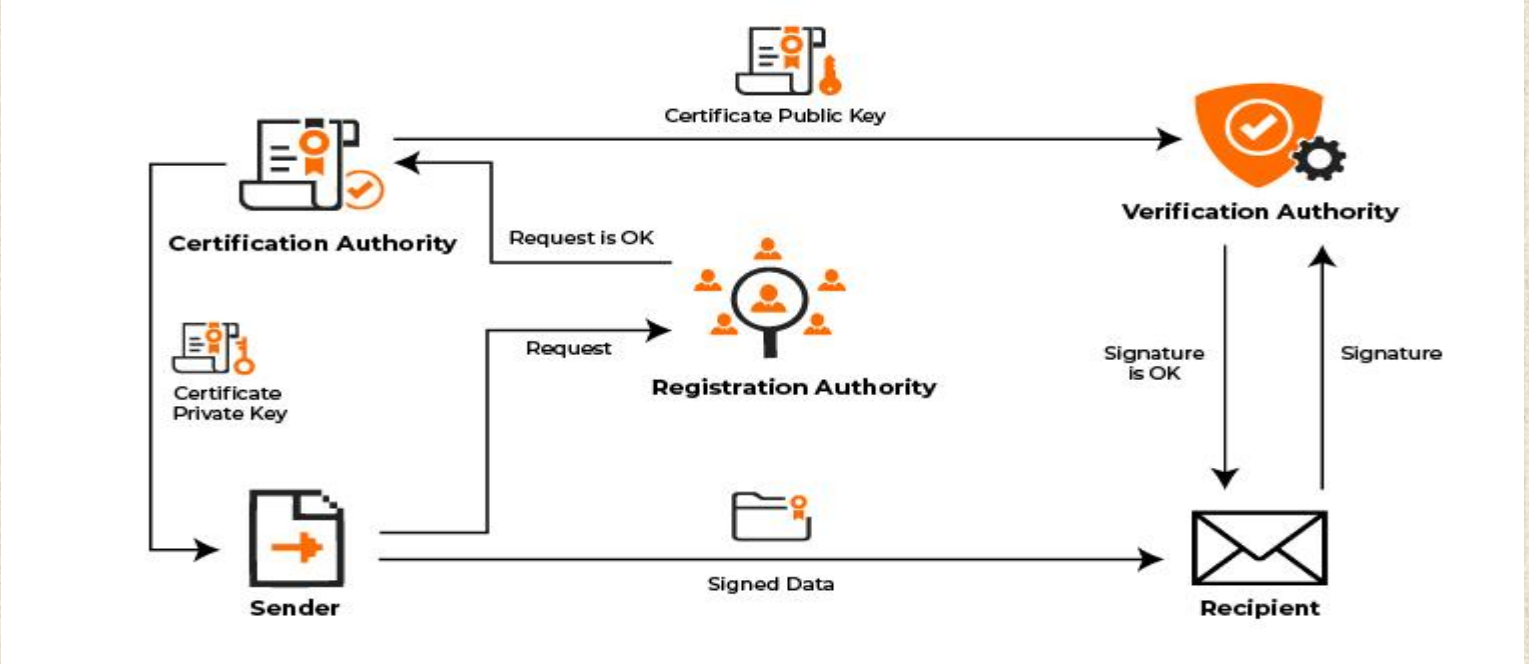


- Here's a basic overview of how Digital Signatures works:
  - Key Generation
    - The process starts with the creation of a pair of cryptographic keys - a private key and a public key.
    - The private key is kept secret and is used for creating digital signatures.
    - The public key is shared openly and is used by others to verify the digital signatures.
  - Signature Creation/ Signing
    - When a sender wants to digitally sign a document, they use their private key to generate a unique digital signature for that specific content.
    - This process typically involves hashing the content (using a cryptographic hash function) to create a fixed-length digest, and then encrypting this digest with the private key.
    - The resulting digital signature is unique to both the content and the signer's private key.

- Signature Verification
  - The recipient of the signed document can verify its authenticity using the sender's public key.
  - They decrypt the digital signature using the public key to obtain the original hash value.
  - Then, they independently hash the received content using the same cryptographic hash function.
  - If the two hash values match, it proves that the content has not been altered since it was signed and that the signature was indeed generated by the owner of the private key.

Public Key Infrastructure (PKI) / Digital Certificate

- PKI is a set of hardware, software, people, policies, and procedures needed to create, manage, distribute, use, store, and revoke digital certificates and manage public-key encryption.
- PKI enables secure communication and transactions over the internet by using cryptographic techniques.
- Digital Certificate is an Electronic “PASSPORT" that allows a person, computer or organization to exchange information securely over the Internet using the public key infrastructure (PKI).
- The Basic figure of PKI is given below;



- Certificate Authority (CA)
  - CA is a trusted entity responsible for issuing, revoking, and managing digital certificates.
  - It verifies the identity of the certificate holder and assures for their authenticity.
  - Well-known CAs include companies like VeriSign, Thawte, and Let's Encrypt.
- Registration Authority (RA)
  - The RA is responsible for verifying the identity of certificate applicants before forwarding their requests to the CA for certificate issuance.
  - It acts as an intermediary between the user and the CA, performing administrative tasks related to certificate issuance.
  - RA’s are specially useful for scaling PKI applications across different geographical locations for example a CA can hand over its responsibilities to different RA’s and assign an area of operation to each RA such as an RA for north region etc.

- Verification Authority (VA)
  - The Validation Authority is responsible for validating digital certificates issued by Certificate Authorities (CAs).
  - It ensures that the certificates presented in a transaction or communication are valid and have not been revoked.
- PKI Clients
  - The entity which request CA's or RA's to issue certificates are commonly referred as PKI clients.
  - It can be a Sender or a Recipient.

- By integrating these components, a PKI system establishes a framework for secure and trustworthy communication, enabling encryption, authentication, and data integrity across various digital applications and services.

- Steps for Obtaining Digital Certificate

1. Identify the Type of Certificate Needed
   - Determine the purpose of the digital certificate, Common types include SSL/TLS certificates for website security, code signing certificates for software developers, and email certificates for secure email communication.
2. Choose a Certificate Authority (CA)
   - Select a trusted Certificate Authority to issue your digital certificate, Some Popular CAs include Let's Encrypt, Digicert, Comodo, and Symantec.
3. Generate a Certificate Signing Request (CSR)
   - Create a CSR, which is a file containing information about your organization and the public key you want to associate with the certificate, The CSR is usually generated on the server where you plan to install the certificate.
4. Submit the CSR to the CA
   - Once you have the CSR, submit it to the chosen Certificate Authority. This process may involve completing an online form and providing additional verification information about your organization.

5. Validation Process
   - The CA will verify the information provided in the CSR, This may include confirming the domain ownership or validating the organization's details.
6. Receive and Install the Certificate
   - After successful validation, the CA will issue the digital certificate.
   - You will receive the certificate file, Install the certificate on the server or device for which it was intended.
7. Configure Server to Use the Certificate
   - Update your server configuration to use the newly installed certificate for secure communication.
8. Test the Certificate Installation
   - Verify that the certificate is correctly installed and functioning. Test the secure connections to ensure that the certificate is being used as expected.
9. Renew the Certificate (if applicable):
   - Digital certificates have a validity period, Monitor the expiration date and renew the certificate before it expires to avoid disruptions in secure services.

- Steps for Verifying Authenticity and Integrity of a Digital Certificate.

1. Check the Certificate Information
   - Review the information contained in the digital certificate.
2. Verify the Certificate Chain
   - Digital certificates often form a chain of trust, with an end-entity certificate being issued by an intermediate CA, which, in turn, is signed by a root CA. Ensure that the certificate chain is valid and that each certificate in the chain is signed by the entity above it
3. Check the Certificate's Validity Period
   - Verify that the digital certificate is still within its validity period.
4. Verify the Certificate's Status
   - Some CAs provide online services to check the status of a certificate, known as Confirm that the certificate has not been revoked or flagged as invalid.
5. Check the Digital Signature
   - Every digital certificate is signed by the issuing CA using its private key. Verify the digital signature on the certificate using the public key of the issuing CA. If the signature is valid, it indicates that the certificate has not been tampered with.

6. Use a Trusted Certificate Authority
   - Ensure that the certificate was issued by a trusted and reputable Certificate Authority.
7. Compare Certificate Details with the Website
   - If the certificate is used for securing a website (e.g., SSL/TLS certificate), compare the certificate details with the information presented by the website. Ensure that the domain name matches and that the certificate is issued for the correct entity.
8. Use Browser Security Indicators
   - Modern web browsers display security indicators, such as a padlock icon or "HTTPS" in the address bar, to signify secure connections. Use these indicators to verify that the certificate is in place and valid.

- Advantages of Digital Certificate
  - Ensure Authentication
  - Ensure Data Integrity
  - Ensure/Maintain Confidentiality
  - Ensure Non-Repudiation
  - Enhance Security
  - Provide Access Control

- Disadvantages of Digital Certificate
  - Dependency on CAs
  - Costly and Complex Process.
  - Revocation Challenges
  - Proper key management is crucial.
  - Compatibility Issues: Ensuring compatibility across different systems and applications can be challenging.
  - Initial Setup and Configuration: Setting up PKI and configuring certificates may require expertise and planning.

Important Questions

Unit-3 (CO-3)	
Sr No.	**Question**
1	Explain How to Achieve Confidentiality Using Public Key Cryptosystems with suitable diagram.
2	Explain How to Achieve Secracy (Authentication) Using Public Key Cryptosystems with suitable diagram.
3	Explain How to Achieve Confidentiality and Secrecy (Authentication) both Using Public Key Cryptosystems with suitable diagram.
4	Explain RSA Algorithm in Detail.
5	Explain Digital Signature in Detail with Suitable Diagram.
6	Explain PKI with Suitable Diagram.
7	List and Explain Steps to Obtaining Digital Certificate.
8	List and Explain Steps to Verifying Authenticity and Integrity of a Digital Certificate